

An Empirical Study of Static Analysis Tools for Secure Code Review

**Wachiraphan Charoenwet, Patanamon Thongtanunam,
Van-Thuan Pham, Christoph Treude
(ISSTA 2024)**

Renato Cazzoletti



Objetivo

Avaliar empiricamente a eficácia de ferramentas SAST em cenários reais de revisão de código seguro, identificando suas limitações na detecção de vulnerabilidades.



Contexto e Motivação

- Falhas de segurança em sistemas críticos podem ter consequências devastadoras — financeiras, operacionais e para os usuários;
- Code review é uma das principais práticas para identificar vulnerabilidades antes que cheguem à produção;
- Ferramentas SAST automatizam essa análise, examinando o código estaticamente sem precisar executá-lo;
- Apesar de amplamente adotadas pela indústria, faltavam evidências empíricas sobre sua eficácia real em projetos do mundo real;



Metodologia





Metodologia

- Coleta de vulnerabilidades reais do banco de dados CVE e as rastrearam até os commits que as introduziram nos projetos
- Cada vulnerabilidade foi mapeada para um commit "vulnerável" e um commit "corrigido", criando pares antes/depois para análise
- As ferramentas SAST foram executadas nos commits vulneráveis e seus alertas foram comparados com as vulnerabilidades reais documentadas
- Um alerta foi considerado verdadeiro positivo somente quando apontava exatamente para o arquivo e região do código onde a vulnerabilidade estava



Resultados

02

76% dos alertas
gerados são falsos
positivos

01

SASTs detectam
vulnerabilidades em
apenas 52% dos casos

03

Nenhuma SAST
sozinha é suficiente



Resultados

- SASTs são insuficientes quando usadas isoladamente — a combinação de ferramentas melhora a cobertura, mas não elimina as lacunas
- A alta taxa de falsos positivos (76%) gera fadiga de alertas, levando desenvolvedores a ignorar avisos importantes
- Vulnerabilidades mais complexas, como falhas de lógica e controle de acesso, são sistematicamente ignoradas pelas ferramentas
- Segurança de software não pode depender exclusivamente de automação — práticas humanas de revisão e cultura de segurança são indispensáveis



Considerações finais

- Um dos primeiros estudos empíricos a avaliar SASTs especificamente no contexto de code review seguro com vulnerabilidades reais
- Fornece evidências concretas que desafiam a confiança excessiva da indústria nas ferramentas SAST
- Os resultados orientam equipes de desenvolvimento a adotar estratégias mais robustas de segurança, combinando ferramentas, processos e revisão humana



Obrigado